TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Apple backports fix for exploited CoreGraphics bug to older iPhones and iPads

From **Cybersecurity Brie ng** · 2026-10-27 to 2026-10-28 (US, Global, Industry; last 24 hours) and 2026-10-23 to 2026-10-28 (Indianapolis, State of Indiana) · Brie ng generated 2026-10-28

REPORT ID	VERSION	HANDLING
LIT-CTI-20261028-01	1.0 · 2026-10-28 08:07 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-27	No update
CVES	**ANALYST**	
CVE-2026-86950 (CVSS 8.8)	Nick Sturgeon	

VULNERABILITY | HIGH | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: HIGH

BOTTOM LINE UP FRONT

Apple has released iOS 18.7.11 and iPadOS 18.7.11, which carry its x for CVE-2026-86950 to older devices. CVE-2026-86950 is an out-of-bounds write in the CoreGraphics framework. Opening or rendering a maliciously crafted le on a vulnerable device can lead to arbitrary code execution. Apple's advisory gives a release date of October 26, 2026, and The Hacker News reported it on October 27 [S1] [S2]. The update covers iPhone XS, XS Max and XR, iPad 7th generation, iPad Air 4th generation and later, iPad 9th generation and later, and iPad mini 6th generation and later [S2]. Apple repeated its statement that it is aware of a report that the flaw may have been exploited in an extremely sophisticated attack against specific targeted individuals on iOS versions before iOS 27 [S2] [S4].

The rst xes shipped on September 28, 2026, in iOS/iPadOS 26.7.1, macOS Tahoe 26.7.1 and macOS Sequoia 15.8.1. Those releases covered only iPhone 11 and later and the newer iPad models [S3] [S7] [S8]. That left devices that cannot run iOS 26 without a x for about four weeks. CISA added the CVE to its Known Exploited Vulnerabilities (KEV) catalog on September 29, 2026 [S4] [S5]. Meta Product Security found the flaw [S2] [S7]. On September 30, researchers at Calif published a patch-diff analysis and a crash-only proof of concept (PoC). In their analysis, a PDF with a crafted embedded TrueType font triggers an inconsistent xed-point conversion in the glyph rasterizer, which leads to an undersized buffer and an out-of-bounds write. They did not show code execution [S10] [S11]. EPSS put the chance of exploitation at about 26% (98th percentile) on October 27 [S6]. Apple says none of the xes in its 27.2 releases, also shipped this week, were exploited [S1].

Several things are still unknown. Apple and Meta have not named the threat actor, the targets, how many

people were targeted, or how the file was delivered. No indicators of compromise have been published [S7] [S8] [S9] [S12]. Calif saw new checks for PDFs with suspicious embedded fonts in WhatsApp's attachment scanner. Calif called this circumstantial and withdrew an earlier claim that WhatsApp was a confirmed delivery path [S10] [S11]. One secondary report links the flaw to Pegasus targeting in Serbia, but it relies on an unnamed source and nothing has corroborated it [S13].

What to do: Find every iPhone and iPad below 18.7.11 (iOS 18 line) or 26.7.1 (iOS 26 line), and Macs below Sequoia 15.8.1 or Tahoe 26.7.1. Update them now, starting with executives, finance staff, legal staff, public officials and anyone else likely to be targeted. Devices that cannot reach a fixed release, such as hardware older than iPhone XS, should be retired or removed from access to corporate data [S2] [S3] [S5].

Key judgments

VERY LIKELY · MODERATE CONFIDENCE
Exploitation of CVE-2026-86950 will very likely stay limited to a small number of high-value individuals, not become broad or commodity use, during the next 30 days. Apple describes the attacks as highly targeted, and the public PoC only causes a crash. [S2] [S7] [S10] [S11]

LIKELY · LOW CONFIDENCE
Now that a working trigger PDF and a root-cause write-up are public, it is likely that a third party will show or claim code execution, or that the PoC will be built into crash or denial-of-service tooling, within the next three months. [S10] [S11] [S6]

LIKELY · MODERATE CONFIDENCE
It is likely that some unpatched iOS 18 devices (iPhone XS/XR and older iPads) remain in small and mid-size business and education fleets, mostly personally owned or lightly managed devices. These will be the slowest group to reach 18.7.11. [S2] [S3]

UNLIKELY · MODERATE CONFIDENCE
It is unlikely that Apple or Meta will publicly name the actor or the delivery vector within the next 30 days. Neither has done so for comparable Apple zero-days in 2026. [S8] [S12]

INDICATORS OF COMPROMISE

None of the sources publish network or file indicators of compromise (IOCs) for in-the-wild exploitation. Apple, CISA and the press all say none have been released [S7] [S8] [S11] [S12]. The entries below are derived from the root-cause analysis and the affected-version data, current as of 2026-10-28. Use them for hunting and exposure checks, not as attribution indicators.

Type	Indicator (defanged)	Context	Provenance	First seen	Source

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`PDF document containing an embedded TrueType font with extreme scaling/text-matrix values`	Calif's analysis triggers the out-of-bounds write with a PDF whose embedded TrueType font, combined with nested scaling and a text matrix, pushes glyph coordinates past the 32-bit fixed-point limit. Attachments of this kind sent to high-risk users deserve a closer look. This is a heuristic for the bug class, not a confirmed in-the-wild sample.	DERIVED	2026-09-30	[S10] [S11]
other	`Crash reports with faulting frames in CoreGraphics glyph rasterization (CoreGraphics.framework) on unpatched iOS/iPadOS/macOS`	The public PoC causes a crash, and Calif reports crashes on both macOS and iOS. Unexplained CoreGraphics crashes after opening or previewing a document on an unpatched device could point to a trigger attempt. Inferred from the PoC behavior.	DERIVED	2026-09-30	[S10] [S11]
other	`iOS/iPadOS 18.x < 18.7.11; iOS/iPadOS 26.x < 26.7.1; macOS Sequoia < 15.8.1; macOS Tahoe < 26.7.1`	Vulnerable OS versions taken from the CVE record and Apple advisories. Use these values in MDM inventory queries to find exposed devices.	DERIVED	2026-09-28	[S2] [S3] [S4]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The flaw is in the CoreGraphics rasterizer, the system framework that renders 2D graphics, fonts and PDFs on iOS, iPadOS and macOS. According to Calif's patch-diff analysis, two of eight rasterizer functions handled overflow differently when converting a floating-point glyph coordinate to 32-bit fixed point: one saturated and the other truncated. The glyph bounding box therefore came out too small, the buffer was allocated too small, and the renderer wrote past its end [S10] [S11]. An attacker has to get a crafted file, likely a PDF with an embedded font, rendered on the target device. The CVSS vector requires user interaction (UI:R) [S4]. CoreGraphics also renders previews and thumbnails, so rendering may happen automatically, for example through a messaging-app attachment preview [S11]. Apple has not disclosed the delivery vector. The WhatsApp link is circumstantial, and one outlet reported no evidence of WhatsApp delivery [S9] [S10]. Apple says the attacks were extremely sophisticated and aimed at specific individuals, which fits a mercenary-spyware style chain. No actor has been confirmed [S2] [S12].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Execution	T1203 Exploitation for Client Execution	A crafted file (per Calif, a PDF with a malformed embedded TrueType font) triggers an out-of-bounds write in CoreGraphics while it renders, which can lead to arbitrary code execution. [S2] [S4] [S10]	Look for CoreGraphics crash reports on unpatched devices. Watch MDM and EDR telemetry on macOS for unusual child processes or memory faults in apps that render documents (Preview, Mail, Messages, messaging clients).
Execution	T1204.002 User Execution: Malicious File	The CVSS vector requires user interaction, meaning the victim opens or previews the malicious file. Automatic previews may reduce how much interaction is needed. [S4] [S11]	Hunt for PDFs with embedded fonts from external or first-time senders delivered to high-risk users. Correlate with later crashes.
Initial Access	T1566.001 Phishing: Spearphishing Attachment	Hypothesized delivery only. Apple has not disclosed the vector. Reporting suggests targeted delivery of the crafted document by email, web or a messaging app, possibly WhatsApp. That link is circumstantial. [S9] [S10] [S11]	Check email gateway logs for PDF attachments sent to executives and other high-risk users from unknown senders. Detonate them in a sandbox where possible.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Intune: iOS/iPadOS devices below fixed CoreGraphics release `KQL`

```
IntuneDevices
| where OS in~ ("iOS", "iPadOS")
| extend v = parse_version(OSVersion)
| where (v >= parse_version("18.0") and v < parse_version("18.7.11"))
    or (v >= parse_version("26.0") and v < parse_version("26.7.1"))
    or v < parse_version("18.0")
| project DeviceName, UPN, Model, OSVersion, LastContact, Ownership
| order by OSVersion asc
```

Requires Intune diagnostic data in Log Analytics. Column names vary by connector, so adjust to your schema. Devices below 18.0 cannot get the fix and should be retired.

Jamf/MDM inventory: unpatched macOS for CVE-2026-86950 `SPLUNK SPL`

```
index=mdm sourcetype=jamf:inventory os_name="macOS"
| eval major=mvindex(split(os_version,"."),0)
| where (major="15" AND os_version!="15.8.1" AND NOT match(os_version,"^15\.(8\.[2-9]|9|1[0-9])")) OR
(major="26" AND NOT match(os_version,"^26\.(7\.[1-9]|[89]|1[0-9])")) OR tonumber(major)<15
| table computer_name, username, os_version, last_checkin
```

Simple version-string matching. Validate it against your inventory field names and version formats.

macOS: CoreGraphics crashes in document-rendering processes `SIGMA`

```
title: CoreGraphics Crash In Document Renderer (CVE-2026-86950 hunting)
status: experimental
logsource:
  product: macos
  category: crash_report
detection:
  selection:
    CrashedThreadFrames|contains: 'CoreGraphics'
    ProcessName:
      - 'Preview'
      - 'QuickLookUIService'
      - 'com.apple.quicklook.ThumbnailsAgent'
      - 'Mail'
      - 'MobileSMS'
      - 'WhatsApp'
  condition: selection
falsepositives:
  - Benign rendering bugs and malformed fonts
level: medium
```

Requires collecting DiagnosticReports (.ips) through EDR or MDM. The field names are illustrative. Most useful on hosts that are not yet patched.

Email: PDFs with embedded fonts to high-risk users from external senders `KQL`

```
let VIPs = dynamic(["ceo@example.org","cfo@example.org"]);
EmailAttachmentInfo
| where FileType =~ "pdf"
| where RecipientEmailAddress in~ (VIPs)
| join kind=inner (EmailEvents | where EmailDirection == "Inbound") on NetworkMessageId
| project Timestamp, SenderFromAddress, RecipientEmailAddress, FileName, SHA256, ThreatTypes
| order by Timestamp desc
```

Defender for Office 365 cannot see embedded font streams. Use this query to choose PDFs for sandbox or static analysis (for example, flagging /FontFile2 objects with unusual matrices).

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Apple iOS / iPadOS 18 (iPhone XS, XS Max, XR; iPad 7th gen; iPad Air 4th gen+; iPad 9th gen+; iPad mini 6th gen+)	< 18.7.11	18.7.11 (released 2026-10-26)	CVE-2026-86950	8.8 (CISA ADP, AV:N/AC:L/PR:N/UI:R)	0.26166 (98.0th percentile, 2026-10-27)	Yes (added 2026-09-29)	2026-10-13
Apple iOS / iPadOS 26 (iPhone 11 and later; newer iPads)	< 26.7.1	26.7.1 (released 2026-09-28); iOS 27 not listed as affected	CVE-2026-86950	8.8	0.26166	Yes (added 2026-09-29)	2026-10-13
Apple macOS Sequoia	< 15.8.1	15.8.1	CVE-2026-86950	8.8	0.26166	Yes (added 2026-09-29)	2026-10-13
Apple macOS Tahoe	< 26.7.1	26.7.1	CVE-2026-86950	8.8	0.26166	Yes (added 2026-09-29)	2026-10-13

Immediate (0–24 hours)

- Pull MDM inventory for all iPhones, iPads and Macs. Flag any device below iOS/iPadOS 18.7.11 or 26.7.1, macOS Sequoia 15.8.1 or macOS Tahoe 26.7.1. `IT OPS` [S2] [S3] [S4]
- Push iOS/iPadOS 18.7.11 to legacy devices (iPhone XS/XR, older iPads) through MDM managed software updates with a short enforcement deadline. Do executives and other high-risk users first. `IT OPS` [S1] [S2]
- Confirm the September fixes (26.7.1 and 15.8.1) are installed on newer iPhones and Macs. The KEV due date of 2026-10-13 has already passed. `IT OPS` [S3] [S5]

Short term (1–7 days)

- Use MDM compliance or conditional access to block corporate email and app access from iOS/iPadOS devices

below the fixed builds until they update. `IT OPS` [S2] [S5]
- Run the hunts in this report for CoreGraphics crashes and unusual PDF attachments sent to high-risk users. Review any unexplained crashes on devices that were unpatched between 2026-09-28 and 2026-10-26. `SOC` [S10] [S11]
- If a high-risk user reports odd device behavior or an Apple threat notification, preserve the device, collect a sysdiagnose, and escalate for mobile forensics instead of wiping it. `SOC` [S2] [S5]

Long term

- Set and enforce a minimum supported OS policy. Retire or replace devices that cannot run a supported, patched iOS release (anything older than iPhone XS/XR). `LEADERSHIP` [S2] [S3]
- Run a high-risk-user mobile program: managed devices, fast patch SLAs (48 hours for Apple exploited-in-the-wild fixes), and an Apple Lockdown Mode evaluation for the most targeted staff. `LEADERSHIP` [S2] [S9] [S12]

Workarounds & compensating controls

- Until devices are patched, turn off automatic media and document download in messaging apps for high-risk users, and tell them not to open unexpected PDFs. `IT OPS` [S10] [S11]
- Consider enabling Lockdown Mode for executives and other high-risk users on devices that cannot update yet. Apple has not said whether Lockdown Mode blocks this specific vector. `IT OPS` [S10]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Apple backports fix for exploited CoreGraphics flaw to older iPhones and iPads
Published 2026-10-27 · `B1` Usually reliable, confirmed by other sources
Briefing source. Matches the Apple advisory.

[S2] Apple: About the security content of iOS 18.7.11 and iPadOS 18.7.11
Published 2026-10-26 · `A1` Completely reliable, confirmed by other sources
Primary vendor advisory for the backport. Credits Meta Product Security.

[S3] Apple: About the security content of iOS 26.7.1 and iPadOS 26.7.1
Published 2026-09-28 · `A1` Completely reliable, confirmed by other sources
Primary vendor advisory for the original fix.

[S4] CVE Program (MITRE CVE Services): CVE-2026-86950 record
Published 2026-09-28 · `A1` Completely reliable, confirmed by other sources
CWE-787. CISA ADP CVSS 8.8 and SSVC exploitation active. Updated 2026-10-26.

[S5] CISA: Known Exploited Vulnerabilities Catalog (JSON feed)
Published 2026-09-29 · `A1` Completely reliable, confirmed by other sources
dateAdded 2026-09-29, dueDate 2026-10-13, ransomware use Unknown. Several press outlets reported an October 2 deadline.

[S6] FIRST: EPSS API: CVE-2026-86950
Published 2026-10-27 · `A2` Completely reliable, probably true
EPSS 0.26166, 97.984th percentile.

[S7] Help Net Security: Apple squashes zero-day bug exploited in "extremely sophisticated" attack (CVE-2026-86950)
Published 2026-09-29 · `B1` Usually reliable, confirmed by other sources
Original-fix coverage. No IOCs or attribution.

[S8] The Hacker News: Apple patches exploited CoreGraphics flaw
Published 2026-09-28 · `B1` Usually reliable, confirmed by other sources
Original-fix coverage with affected device list.

[S9] Security Affairs: Apple Patches CoreGraphics Zero-Day Linked to Sophisticated Targeted Attacks
Published 2026-09-29 · `B2` Usually reliable, probably true
Says there is no evidence of WhatsApp delivery and recommends prioritizing high-risk users. Written before the KEV listing.

[S10] The Hacker News: Apple CoreGraphics PoC emerges
Published 2026-10-01 · `B2` Usually reliable, probably true
Reports on Calif's root-cause analysis and crash PoC, the WhatsApp scanner changes and the retracted WhatsApp delivery claim. The PoC repository itself was not visited.

[S11] Security Affairs: Public PoC Released for Apple CoreGraphics Zero-Day CVE-2026-86950
Published 2026-10-01 · `B2` Usually reliable, probably true
Corroborates S10 on the root cause and that code execution was not demonstrated.

[S12] The Register: Apple fixes CoreGraphics zero-day
Published 2026-09-29 · `B2` Usually reliable, probably true
No attribution or IOCs. Calls this the seventh Apple zero-day of 2026, a count other outlets dispute.

[S13] BornCity: Apple-Sicherheitsupdate: CoreGraphics-Lücke wird bereits für Angriffe genutzt
Published 2026-10-05 · `C4` Fairly reliable, doubtful
Repeats an unnamed report linking the flaw to Pegasus targeting of 14 people in Serbia. Not corroborated by any other source reviewed. Also reports a CERT-In advisory dated 2026-10-01.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number =

information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-09-08	CVE-2026-86950 reserved by Apple.	[S4]
2026-09-28	Apple fixes the flaw in iOS/iPadOS 26.7.1, macOS Tahoe 26.7.1 and macOS Sequoia 15.8.1, noting possible exploitation against targeted individuals.	[S3] [S8]
2026-09-29	CISA adds CVE-2026-86950 to the KEV catalog (federal due date 2026-10-13 per the feed).	[S5]
2026-09-30	Calif publishes a patch-diff root-cause analysis and a crash-only PoC (malicious PDF with embedded TrueType font).	[S10] [S11]
2026-10-05	Secondary report repeats an unverified claim linking the flaw to Pegasus targeting in Serbia.	[S13]
2026-10-26	Apple releases iOS/iPadOS 18.7.11, backporting the fix to iPhone XS/XR and older iPads. CVE record updated.	[S2] [S4]
2026-10-27	Backport reported publicly. Apple also ships its 27.2 platform releases with no exploited flaws noted.	[S1]

Relevance to Indianapolis, Indiana & Lucidia IT clients

Indianapolis and Indiana organizations most likely to still run iOS 18 hardware (iPhone XS/XR, iPad 7th and 9th generation) are K-12 districts and universities with iPad carts, healthcare providers that use iPads for check-in or clinical carts, local government field staff, and small businesses with older personally owned phones that access email. Few of these users are the targets of the reported attacks, but their devices are still exposed to anyone using the now-public trigger. State and local officials, hospital executives and manufacturing leaders with valuable IP fit the targeted-individual profile Apple describes. For Lucidia IT managed clients: run the MDM version report this week, push 18.7.11 with a deadline, use conditional access to block corporate data on non-compliant iOS devices, and flag any client still running pre-XS hardware for replacement. Clients with state contracts may also want to follow the KEV due date as a benchmark, even though it does not formally apply to them.

Intelligence gaps

- No threat actor, target set, victim count or delivery vector has been disclosed by Apple or Meta.
- No in-the-wild exploit sample, hashes or network indicators are public. The full exploit chain, including any sandbox escape or kernel stage, is unknown.
- Whether exploitation hit iOS 18 devices specifically during the four weeks before the backport is not stated.
- The WhatsApp delivery theory and the Pegasus/Serbia claim are unconfirmed. Watch for statements from Meta/WhatsApp, Citizen Lab or Amnesty Tech.

- Whether Lockdown Mode blocks this attack path has not been stated.

Other notes

- Date discrepancy: the brie ng and The Hacker News date the backport October 27, while Apple's advisory gives October 26, 2026.
- KEV due date discrepancy: several press reports cite October 2, 2026, while the CISA KEV JSON feed lists 2026-10-13. This report uses the feed value. The KEV entry also references BOD 26-04 forensics triage guidance.
- iOS/iPadOS 18.7.11 also xes CVE-2026-65339 (Audio information leak) and CVE-2026-86990 (CoreMedia camera access without permission). Apple did not mark either as exploited.
- The concurrent 27.2 releases (iOS, iPadOS, macOS Golden Gate, tvOS, watchOS, visionOS, Safari) x many bugs, including CVE-2026-86987 in Apple Intelligence. None were reported as exploited.
- EPSS values differ by source and date. FIRST reported 0.26 on 2026-10-27, and secondary outlets cited gures from about 1% to 0.81 at earlier dates.

LIT-CTI-20261028-01 v1.0 · Generated 2026-10-28 08:07 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

TLP:CLEAR Unrestricted public release.